Identity & Access Management Workflows — Joiner, Mover, Leaver & Entitlement Review Framework

Prepared By. Alister A. Rodrigues, Security Analyst, Obsidian SecureTech Solutions

Operational Context. *Reference Architecture for Enterprise IAM Implementation*

Date. October 2024

Executive Summary

This document provides Identity and Access Management (IAM) workflows for organizational information security and upholding compliance standards by managing user access at every stage of the employee lifecycle.

The Joiners workflow ensures new hires are swiftly and securely integrated with the organization by making use of automated tools for Role Based Access Controls (RBACs) for streamlining and minimizing errors during access management.

The Movers workflow manages the employees during the transfer and promotional stages by reviewing existing permissions ensuring adherence to the principle of least privilege.

The Leavers workflow emphasizes on the departing employees prompt access revocation by freezing access rights and transfer of ownership of account, data and devices previously assigned to the employee.

The Entitlement Reviews workflow ensures scheduled audits of employees access rights and remediation of excessive and outdated permissions.

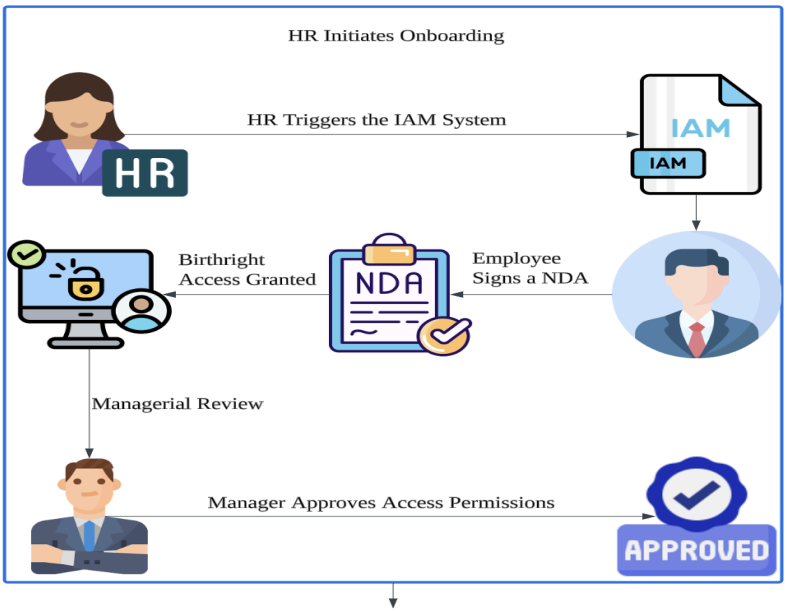
These approaches to different workflows are integrated to form a comprehensive IAM system ensuring consistency in access management, minimizing the risk of manual errors and increasing operational efficiency by automating the birthright access process reducing overhead on IT teams through implementing RBACs, preventing conflict of interests and ensuring no single employee has unfettered access over sensitive data and operations thus protecting organizational assets by implementing Separation of Duties(SoD), security awareness training and having employees sign an Acceptable Use Policy ensuring the employees understanding regarding data security.

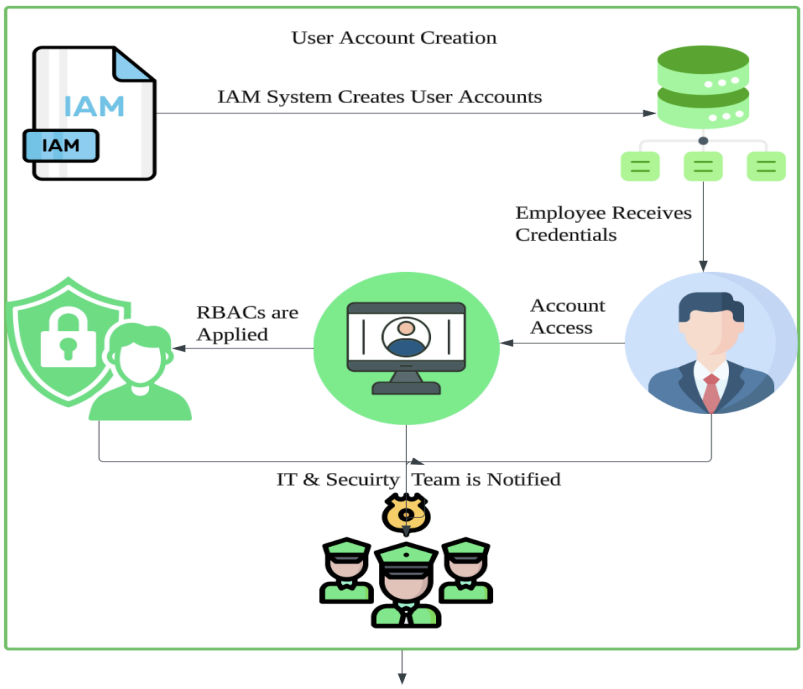
The workflows are designed to ensure adherence to the organizational policies, legal requirements and data security standards like ISO/IEC 27001, GDPR, HIPAA, and NIST.

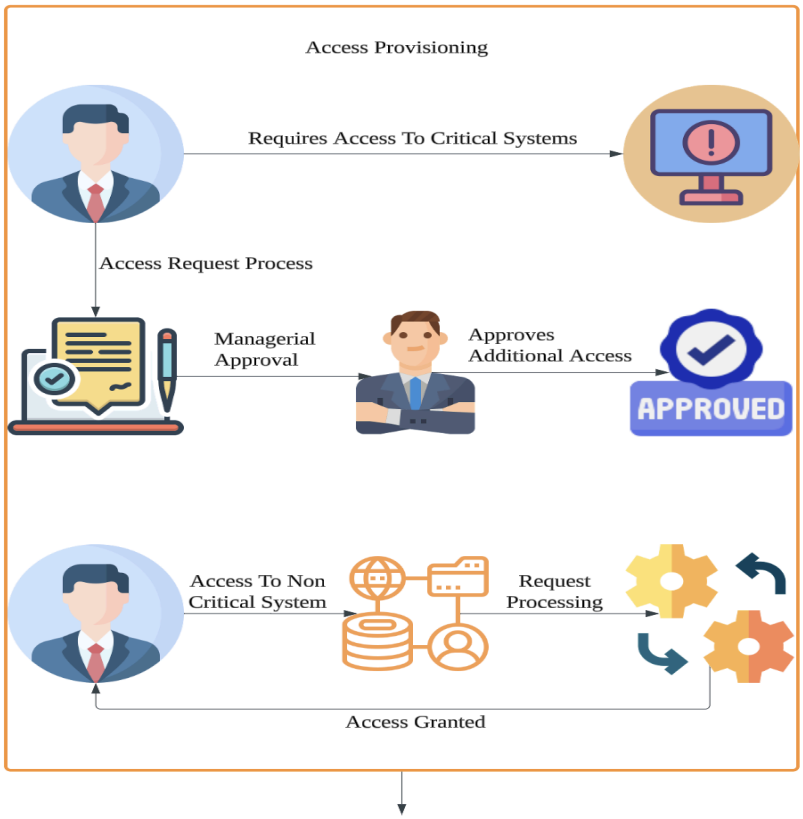
Joiners Onboarding Workflow

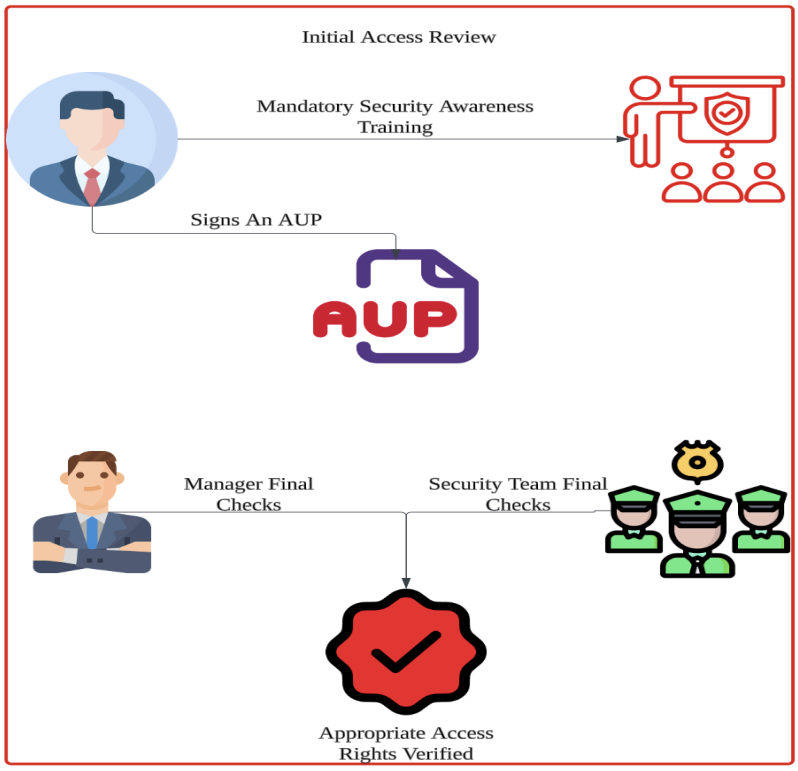
This workflow provides an efficient, secure and compliant process for onboarding of new employees, ensuring they receive the appropriate access based on their job roles while minimizing the risk from unauthorized access to privileged systems.

Workflow Design






Access Provisioning
Requires Access To Critical Systems
Access Request Process
Managerial Approval
Approves Additional Access
APPROVED
Access To Non Critical System
Request Processing
Access Granted


Initial Access Review
Mandatory Security Awareness Training
Signs An AUP
AUP
Manager Final Checks
Security Team Final Checks
Appropriate Access Rights Verified

Initiate Onboarding

HR Notification. HR initiates the onboarding process in the system and triggers a request in the Identity Access Management (IAM) system.

Birthright Access. . Have the employee sign a Non Disclosure Agreement (NDA) for security purposes before providing access rights to protect sensitive company information and ensure confidentiality. Once the employee signs the NDA, based on their job role and the department, birthright access (basic access for all employees) is granted to the employee through organizational policies and Role-Based Access Controls (RBAC).

Approval Process. The manager then reviews and approves the assigned access rights to prevent any risk of access control failure.

User Account Creation

Account Setup. The IAM creates user accounts in relevant systems (e.g. organization email, central directory).

Implementing RBAC. Role-based access controls are used to grant additional permissions required for the job role.

Notification. The new employee receives their login credentials and the relevant teams such as IT and Security are informed about account creation and access rights granted to the new employee.

Access Provisioning

Specialized Access Requests. If the employee requires additional permissions for access to systems containing sensitive information (e.g. financial data or customer data), these are then requested through an access request process that requires the manager's approval.

Provisioning Tools. Automated tools are deployed that will provision access necessary to applications not requiring any managerial approval.

Initial Access Review

Security Training. New employees are required to complete the mandatory security awareness training program and sign an Acceptable Use Policy (AUP) document.

Access Validation. Manager and the Security team conduct a final check to ensure all necessary access has been granted appropriately.

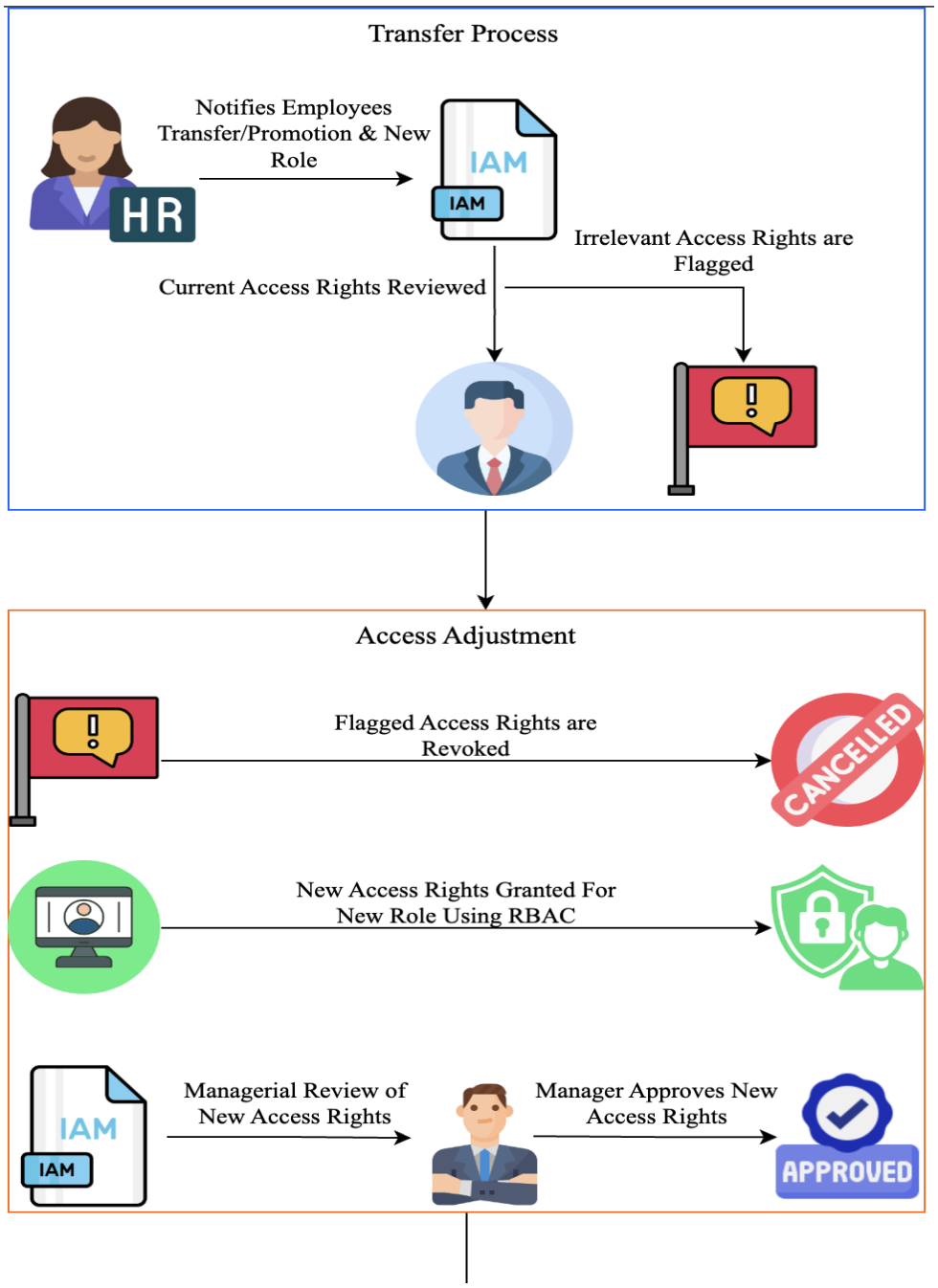
Design Logic

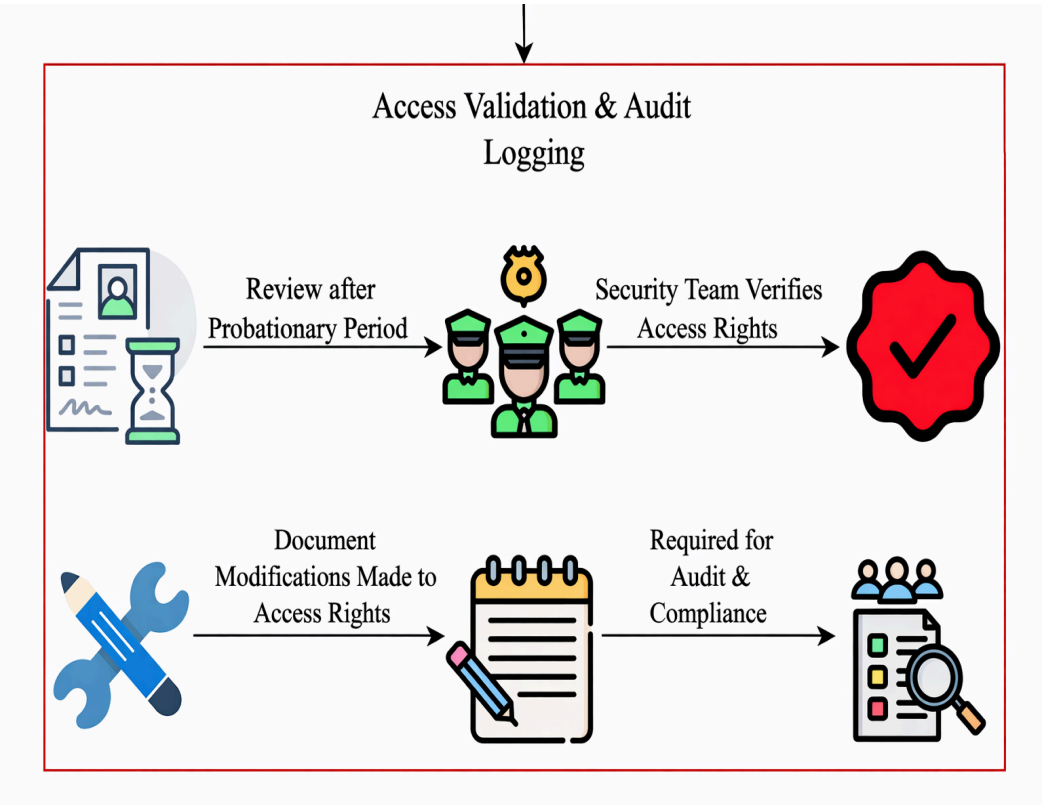
RBAC simplifies access management by assigning permissions based on roles instead of assigning individual access rights thus minimizing any manual errors also allowing to enable effective Separation of Duties(SoD) preventing any conflict of interest and reducing risk of security errors and risks from employees. Birthright access ensures that the employees have essential tools and access required for their job role to complete their tasks immediately upon joining. The security awareness training and the signing of AUP documents minimize risk by ensuring users understand the security requirements and helps to meet the security compliance for standards like ISO/IEC 27001(ISO, 2022), NIST (NIST, 2020), GDPR (GDPR, 2016).

Movers Workflow

This workflow provides efficient and secure changes in access rights for employees from removal of access rights not required for the current role to assigning new access rights for their current role when they get promoted or transferred to a different job role or division.

Workflow Design





Transfer Process

HR Process. The HR department notifies the IAM system of an employee's transfer or promotion and their role change with the details.

Access Review. Employee's current permissions are assessed and the ones that are no longer required for their new job role are flagged for removal.

Access Adjustment

Access Revocation. All permissions that were flagged for removal earlier during access review are removed.

New Access Rights. New permissions and access rights are granted to the employee based on their new job role using role-based access controls.

Managers Approval. The manager is informed of the change in access rights of the employee and gives his approval after reviewing the access rights.

Access Validation & Audit Logging

Review Period. After a probationary period duration, conduct a review to confirm and verify that the access rights provided to the employee is appropriate and aligns with their job responsibilities.

Record Changes. All modifications done to the employees' access rights are to be logged for auditing and compliance purposes.

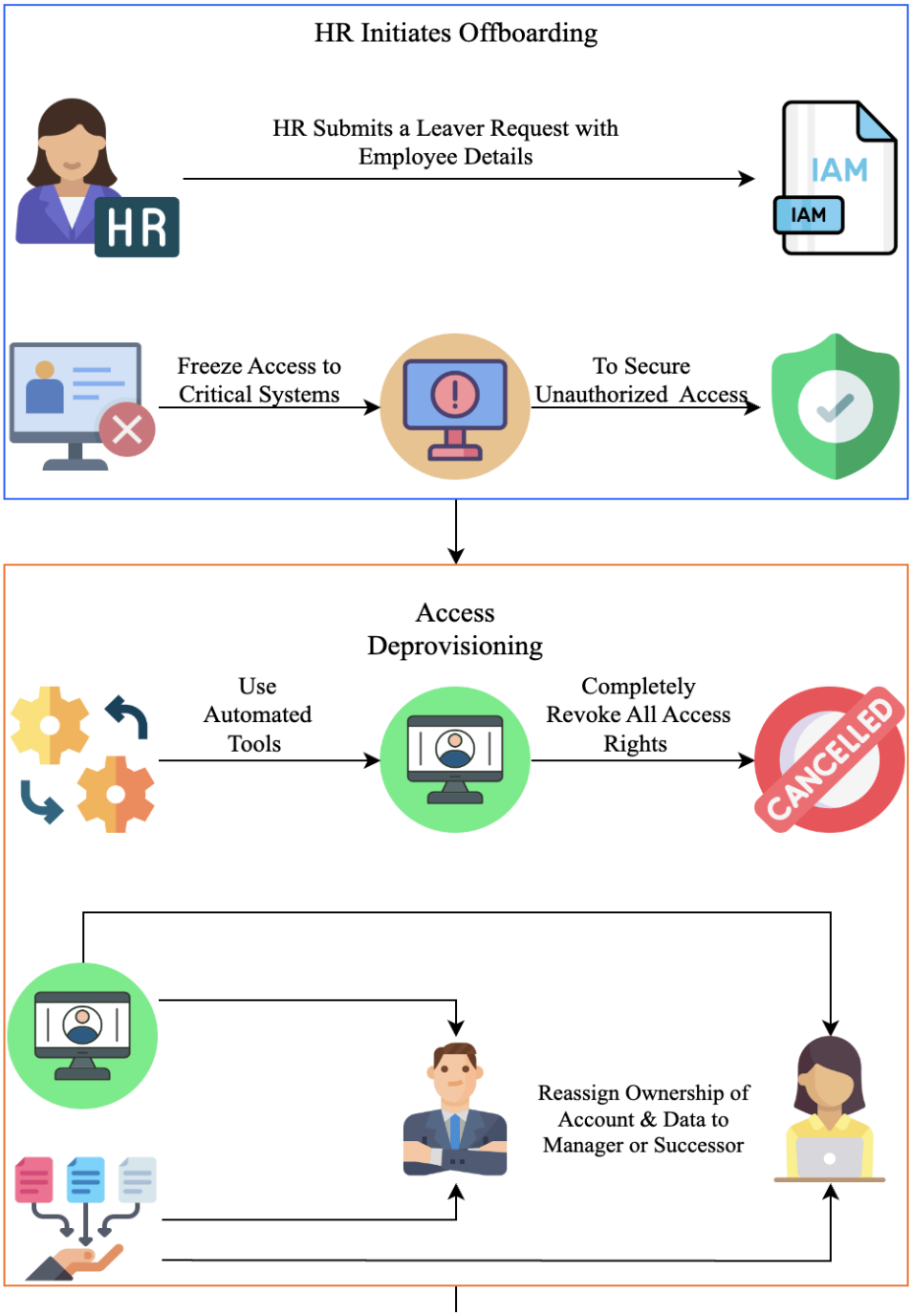
Design Logic

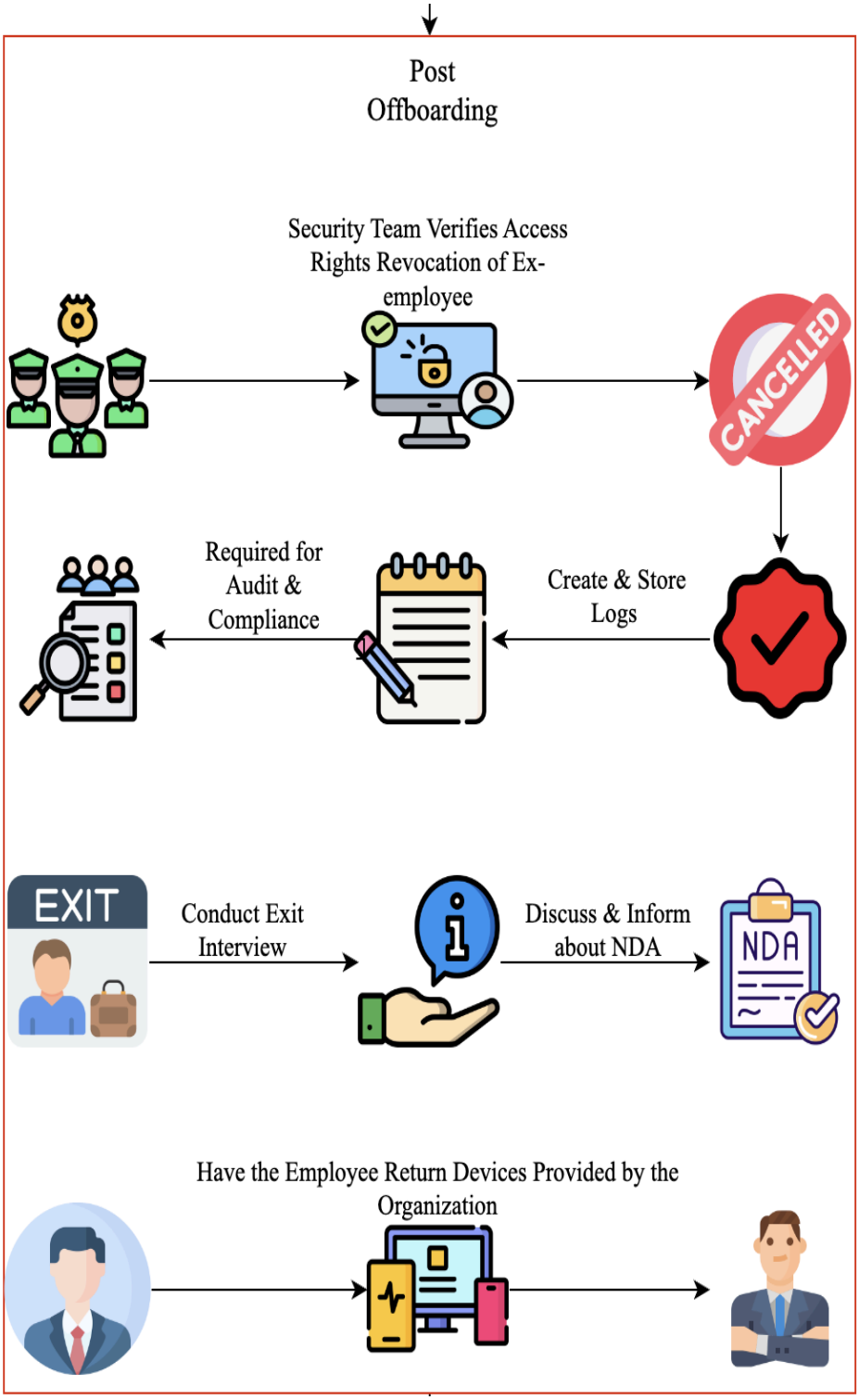
Removing irrelevant permissions associated with the employee's previous job role ensures that the principle of least privilege is upheld by the organization, which reduces exposure to insider threats and sensitive data and limits the employees access to only what is essential for their current responsibilities. RBAC ensures that permissions once again align with the new job roles functions supporting security and operational efficiency and avoiding conflicts of interests with other job roles in that division by enabling Separation of Duties.

Leavers Offboarding Workflow

This workflow provides a process for prompt and complete revocation of all access for employees who resign or are terminated from the organization, while ensuring data security and compliance with regulatory standards.

Workflow Design





Initiate Offboarding

HR Process. HR submits a leaver request and informs the IAM system of an employee's departure with their last working date.

Freeze Access. On the last working day, immediately disable account and deactivate access to critical systems to prevent security risks and unauthorized access.

Access Deprovisioning

Access Removal. Completely revoke all access either using automated tools or manually depending on the employees position within the organization and permissions with access to critical systems.

Data & Account Transfer. Reassign the ownership of the employee's account and critical data (e.g. emails and documents) to their manager or a designated successor for that employee's job role.

Post Offboarding

Verification & Logging. The IT team shall verify and confirm that all access rights of the ex-employee have been revoked duly and store the logs for audit and compliance purposes.

Exit Interview. Discuss and inform the ex-employee about the security concerns and the confidentiality obligations under the Non Disclosure Agreement (NDA) signed during the initial stages of the onboarding process. Have the employee return any devices provided by the company to complete his job related tasks.

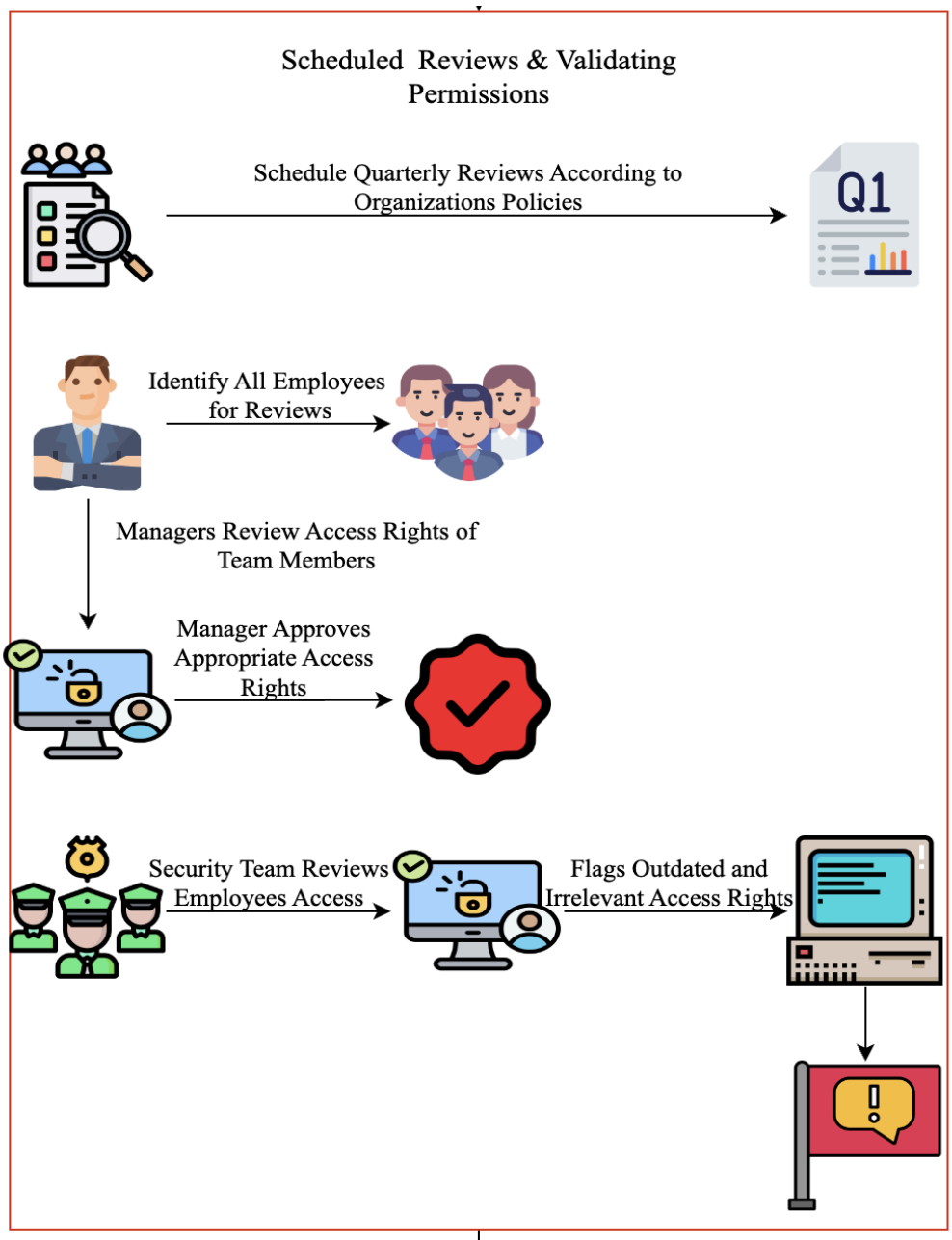
Design Logic

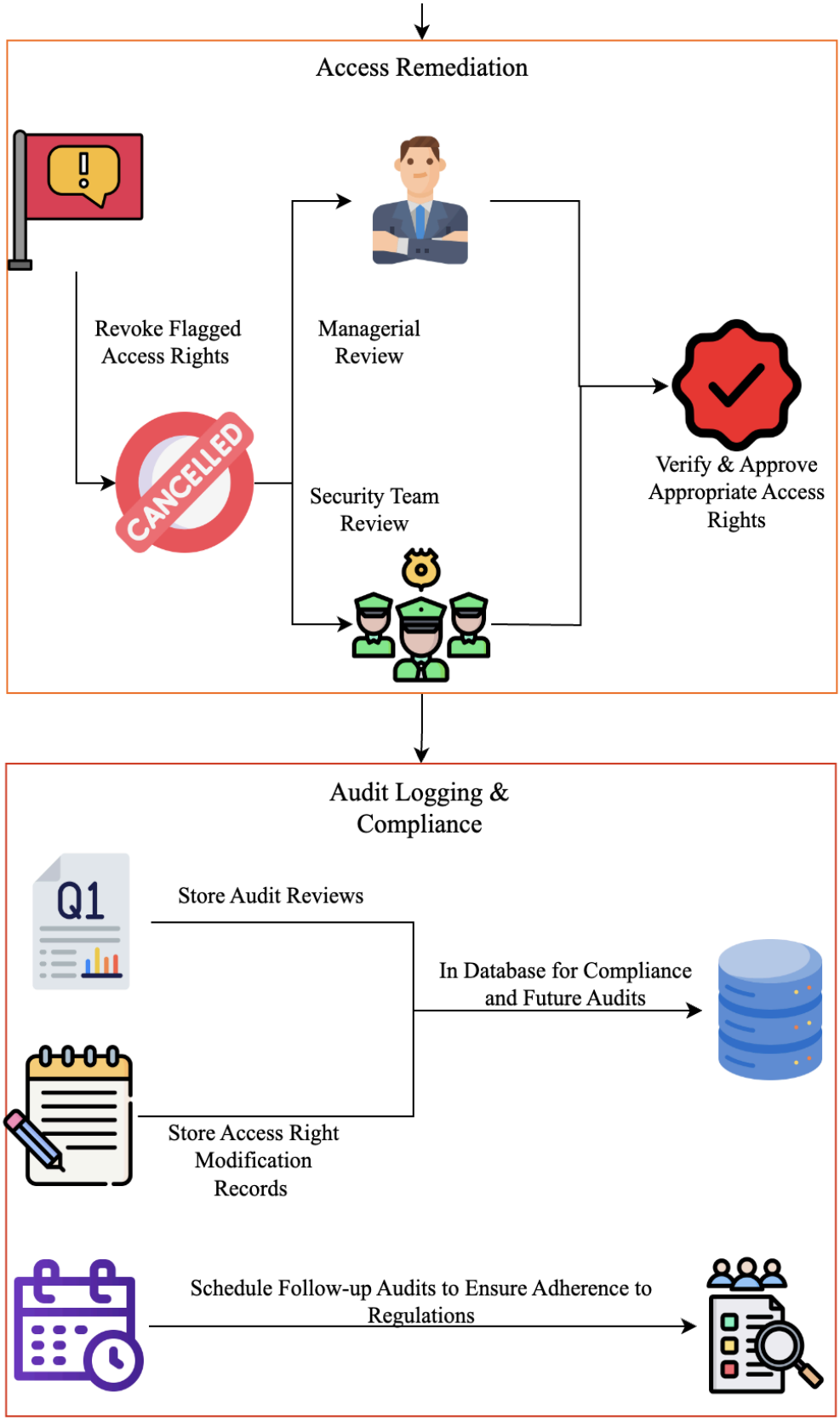
Disabling access immediately ensures that the ex-employee can no longer access critical systems and data thus minimizing the risk of unauthorized access and data loss. Data and account ownership transfer ensures operational continuity for the business while securing sensitive data. Audit logging and the exit interview ensures that records are maintained for regulatory and compliance purposes to data standards like HIPAA (*Termination Procedures*, 2014).

Entitlement Reviews and Approvals Workflow

This process ensures that the employee's access rights are regularly reviewed and validated ensuring their necessity to the employee and compliance with security policies of the organization.

Workflow Design




Access Remediation
Revoke Flagged Access Rights
CANCELLED
Managerial Review
Security Team Review
Verify & Approve Appropriate Access Rights
Audit Logging & Compliance
Q1
Store Audit Reviews
In Database for Compliance and Future Audits
Store Access Right Modification Records
Schedule Follow-up Audits to Ensure Adherence to Regulations

Scheduled Reviews

Frequency & Scope. Conduct entitlement reviews quarterly as per the organization's policies and identify all employees and their current permissions for review.

Review & Validate Permissions

Manager Review. The managers review access rights of their team members to check against their current role requirements.

Security Audit. The security team identifies any outdated, excessive and irrelevant permissions that no longer align with the employees job responsibilities.

Access Remediation

Revoking Excessive Permissions. Revoke any unnecessary access identified during the review process to prevent unauthorized access and reduce security concerns.

Approval. Approve current permissions for the employee if deemed appropriate by the security team and the manager.

Audit Logs & Compliance Reporting

Audit Records. Maintain detailed records of all reviews and actions taken, document the findings in the compliance reports.

Regulatory Compliance. Schedule follow up audits as required by organizational policies and regulatory standards and ensure adherence to regulations like GDPR, HIPAA and ISO/IEC 27001.

Design Logic

Regular reviews and documentation ensures a streamlined auditing process and compliance checks and they are also essential for implementing least privilege access, ensuring minimal access for employees and reducing security risks.

References

GDPR. (2016). *General Data Protection Regulation (GDPR)* . General Data Protection Regulation (GDPR). https://gdpr-info.eu

ISO. (2022). *ISO/IEC 27001 standard – information security management systems*. ISO. https://www.iso.org/standard/27001

NIST. (2020). Security and Privacy Controls for Information Systems and Organizations. *Security and Privacy Controls For Information Systems and Organizations*, *5*(5). https://doi.org/10.6028/nist.sp.800-53r5

Termination Procedures. (2014). https://www.hipaatraining.net/wp-content/uploads/2016/01/Sample-HIPAA-Security-Policy.pdf